

Dara F. Thomas

GRC Analyst | Security+ | SOC 2 & ISO 27001 | 10+ Years Managing Risk in Regulated Industries

Atlanta, GA (Remote) | 619-361-3592 | dara.thomas.grc@gmail.com | [linkedin.com/in/daraftthomas](https://www.linkedin.com/in/daraftthomas) | github.com/DaraStaysCurious

SUMMARY

GRC analyst combining over 10 years of safety and regulatory risk management in manufacturing, maritime, and offshore energy with 6 years of UX research into how people work in B2B SaaS. Applies both to SOC 2 and ISO 27001 gap analysis, control mapping, and vendor risk in case-study compliance programs. Achieved 14 consecutive quarters without a major regulatory citation; designs controls that pass audit and hold up in real use.

CERTIFICATIONS

CompTIA Security+ | AWS Certified Cloud Practitioner (in progress) | Certified GRC Engineer - Auditor (in progress)

AREAS OF EXPERTISE

- **Frameworks & Standards:** SOC 2 Type II, ISO 27001:2022, HIPAA Security Rule, NIST CSF 2.0, NIST SP 800-30, PCI DSS v4.0
- **Risk & Compliance:** Risk assessment and risk register management, control mapping and gap analysis, third-party/vendor risk management, audit readiness and evidence collection, policy and procedure development
- **Methods & Tools:** ISO 19011 internal audit methodology, root cause analysis (Five Whys), Fine-Kinney risk scoring, ServiceNow (App Engine Studio), process mapping and stakeholder interviews
- **Communication & Collaboration:** Stakeholder alignment, communicating risk to leadership, workshop facilitation, training

KEY ACHIEVEMENTS

- **Audit Remediation:** Closed 100% of validated findings from comprehensive Process Safety Management audits, typically 25 - 40+ complex findings per audit, within 30 - 90-day corrective action tracking windows.
- **Regulatory Compliance:** Owned safety and regulatory risk governance for a 270-employee manufacturing plant, achieving 14 consecutive quarters without a major regulatory citation.
- **Cross-Functional Remediation:** Translated risk and process-gap findings into remediation plans with product and engineering teams across 30+ B2B SaaS engagements, reducing user-reported errors by an estimated 35%.
- **Gap Analysis & Control Mapping:** Scoped 47 applicable ISO 27001:2022 Annex A controls for a case-study workforce safety SaaS platform handling employee health records, identifying 29 critical and high-severity gaps and mapping them to HIPAA and NIST CSF 2.0.

PROFESSIONAL EXPERIENCE

Independent Consultant, Self-Employed | *Remote, Part-Time* | 01/2020 - Present

- Conducted risk assessments and stakeholder audits across 30+ B2B SaaS client engagements, applying Fine-Kinney risk scoring and Five Whys root cause analysis to surface workflow and control gaps.
- Partnered with product and engineering teams to convert process-gap findings into prioritized remediation plans.
- Presented findings to client leadership; formalized the method into a repeatable gap-analysis framework.

Sr. UX Designer, Child Care Aware of America | *Arlington, VA (Remote)* | 11/2023 - 02/2025

- Designed and launched a voucher portal handling sensitive family data, now used by 15,000+ military families and replacing 7 hours of manual processing weekly.
- Surfaced 4 critical workflow risks pre-launch via usability testing and stakeholder interviews, enabling early remediation.
- Ran process analysis and risk reviews across 7 major features, documenting control-relevant changes for audit readiness.

Associate UI/UX Designer, Point B | *Portland, OR (Remote)* | 08/2021 - 10/2022

- Facilitated workflow mapping workshops with 8 cross-functional teams to prioritize remediation on a training platform.
- Cut support requests by an estimated 27% and lifted completion rates by redesigning flows around risk findings.

Logistics Coordinator, Robert Half Agency | *Atlanta, GA* | 02/2019 - 03/2020

- Resolved 60+ client shipment issues weekly, coordinating cross-functional response across 15 dispatchers.

Program Assessment Associate, United Way of San Diego County | San Diego, CA | 05/2018 - 01/2019

- Conducted 80+ stakeholder interviews and 100+ program assessments to inform funding and outreach decisions.

Dispatch & Vendor Coordinator, Brinks Plumbing Services | San Diego, CA | 03/2017 - 05/2018

- Coordinated maintenance operations, vendor relationships, and accounts payable across multiple apartment complexes.

Career Break - International Relocation, Canada to United States (09/2015 - 03/2017). Focused on professional development in preparation for the next phase of career transition.

Occupational Health, Safety & Risk Manager, Unilever Bramalea | Toronto, Canada | 10/2008 - 09/2015

- Reduced monthly incident investigations from 3 to 1 at a 270-employee edibles plant through risk-based hazard controls.
- Managed the policy lifecycle for the incident response plan and 8 critical task procedures, including a hoist fall-hazard redesign (4-strap tote bags) that reduced bag failures and fall risk.
- Audited to ISO 14001 and OHSAS 18001 using ISO 19011, which underpins ISO 27001 internal audits (ISO/IEC 27007).

Occupational Health, Safety & Risk Manager, Unilever Caribbean | Trinidad, W.I. | 08/2004 - 10/2008

- Directed safety and compliance across 2 plants (edibles, 20 employees; detergents, 35), running twice-daily walkabouts, weekly safety meetings, and quarterly audits.
- Led comprehensive Process Safety Management audits, tracking corrective actions to closure within 30 - 90 days.
- Reduced safety incidents by an estimated 33% by remediating two root causes: installing non-removable machine guards, and floor resurfacing paired with more frequent cleaning.

Occupational Health, Safety & Risk Manager, Tucker Energy Services | Offshore Oil Rigs, Trinidad, W.I. | 08/2003 - 08/2004

- Conducted monthly HSE and Process Safety Management audits across 2 oil rigs, plus quarterly cross-functional audits with supervisors and union reps.
- Authored or revised 15 critical task procedures; delivered monthly safety training to ~110 employees across both sites.

Health, Safety & Risk Manager, Royal Caribbean | Radiance of the Seas, Brilliance of the Seas | 07/2000 - 08/2003

- Reduced incident investigations from 7 - 8 to 2 per 6-month cycle across 2 cruise vessels through root cause analysis.
- Led a 20-person emergency response team, improving response time by 10%; twice named Employee of the Quarter.

PRACTICAL GRC PROJECTS (SELF-DIRECTED)

OccuSafe - ISO 27001 / HIPAA / NIST CSF 2.0 (case study): Performed an ISO 27001:2022 gap analysis for a workforce safety SaaS platform handling employee health records; assessed vendor risk for three HRIS integrations (Workday, ADP, BambooHR) using public SOC 2/ISO attestations; built a linked Policy-Control-Risk data model in ServiceNow App Engine Studio.

Carestream - SOC 2 Type II / HIPAA Audit Readiness (case study): Built a SOC 2 Type II readiness assessment integrated with HIPAA for a healthcare SaaS company.

TrustPath - Usable Security (case study): Assessed a B2B SaaS vendor risk platform against SOC 2 and NIST CSF, paired with a human-risk assessment using UX research methods to explain why controls get bypassed under deadline pressure.

PayGuard - PCI DSS v4.0 Compliance Program (case study): Designed a PCI DSS v4.0 program for a payment processor, covering controls and audit readiness.

Risk Methodology - Fine-Kinney × NIST SP 800-30: Built a crosswalk between Fine-Kinney risk scoring and NIST SP 800-30, proposing Exposure as an explicit risk-model variable; applied it to three OHS incident case studies.

Portfolio: darasecures.cloud | GitHub: github.com/DaraStaysCurious

COMMUNITY & PROFESSIONAL ENGAGEMENT

Director of Membership (Volunteer), GRC Engineering Club - Atlanta Chapter | Atlanta, GA | 08/2026 - Present

EDUCATION

University of Toronto, Canada - Honors B.A. Sociology and Equity Studies